

Executive Summary

TechGlobal has grown quickly, but its security governance has not kept pace. Security decisions are concentrated with the IT Director, there is no formal committee structure, business units act inconsistently, and the Board has limited visibility into cyber risk. This creates single points of failure, weak segregation of duties, and no reliable path for material risks to reach executive management or the Board.

This report sets out a redesigned governance model built on three principles: clear accountability for every governance activity, formal forums where cross-functional decisions are made collectively, and a defined path for risk information and decisions to move from operational teams to the Board. The model uses a three-tier structure, a Board and Audit & Risk Committee for oversight, an Executive Security Council for strategic decisions, and a Security Governance Committee with supporting working groups and business unit liaisons for day-to-day governance.

The report is organised around five tasks. Task 1 diagnoses the current weaknesses and proposes a governance architecture and stakeholder map. Task 2 defines responsibility and decision authority for each core role. Task 3 designs the committee ecosystem and its supporting artefacts. Task 4 builds a RACI matrix covering fifteen governance activities. Task 5 designs a cyber-risk escalation workflow and a segregation-of-duties weakness register. Each task includes the required evidence in table or diagram form, followed by a short narrative explanation.

Taken together, these artefacts give TechGlobal a governance model that is proportionate to a 2,500-employee, five-office technology organisation: light enough to operate without adding unnecessary bureaucracy, but structured enough to give the Board defensible assurance over cyber risk.

Task 1: Governance Architecture and Stakeholder Map

Governance Gap Assessment

TechGlobal's current model can be described as security by informal decision. The table below sets out six weaknesses in that model, each with its business or risk consequence.

No.	Weakness	Description	Business / Risk Consequence
1	Security authority concentrated in one role	The IT Director acts as security owner, risk approver and operational decision-maker with no independent check.	Single point of failure; decisions may favour technical convenience over business risk appetite; no independent challenge to risk decisions.
2	No formal governance committee structure	Security decisions are made ad hoc, without a defined forum for cross-functional input.	Legal, Finance and HR risk are not systematically considered; decisions can be contradictory or duplicated across functions.
3	Inconsistent practice across business units	Business unit leaders make local security choices with no shared standard across the five offices.	Uneven risk exposure, duplicated tooling and cost, and a harder incident response because controls differ office to office.
4	No formal escalation path	There is no defined route for a risk identified at operational level to reach executive management or the Board.	Material risks can remain hidden until they become incidents; response is reactive rather than managed.
5	Limited Board visibility into cyber risk	The Board receives little structured reporting on cyber risk exposure or governance performance.	The Board cannot discharge its oversight duty; strategic decisions (expansion, new products) may be made without factoring in cyber exposure.
6	Weak segregation of duties	The same role designs, implements and approves security controls and budget.	Self-approval bias; under-investment or poor control quality can go unchallenged; weak audit trail for regulators and auditors.

1.2 Stakeholder Map

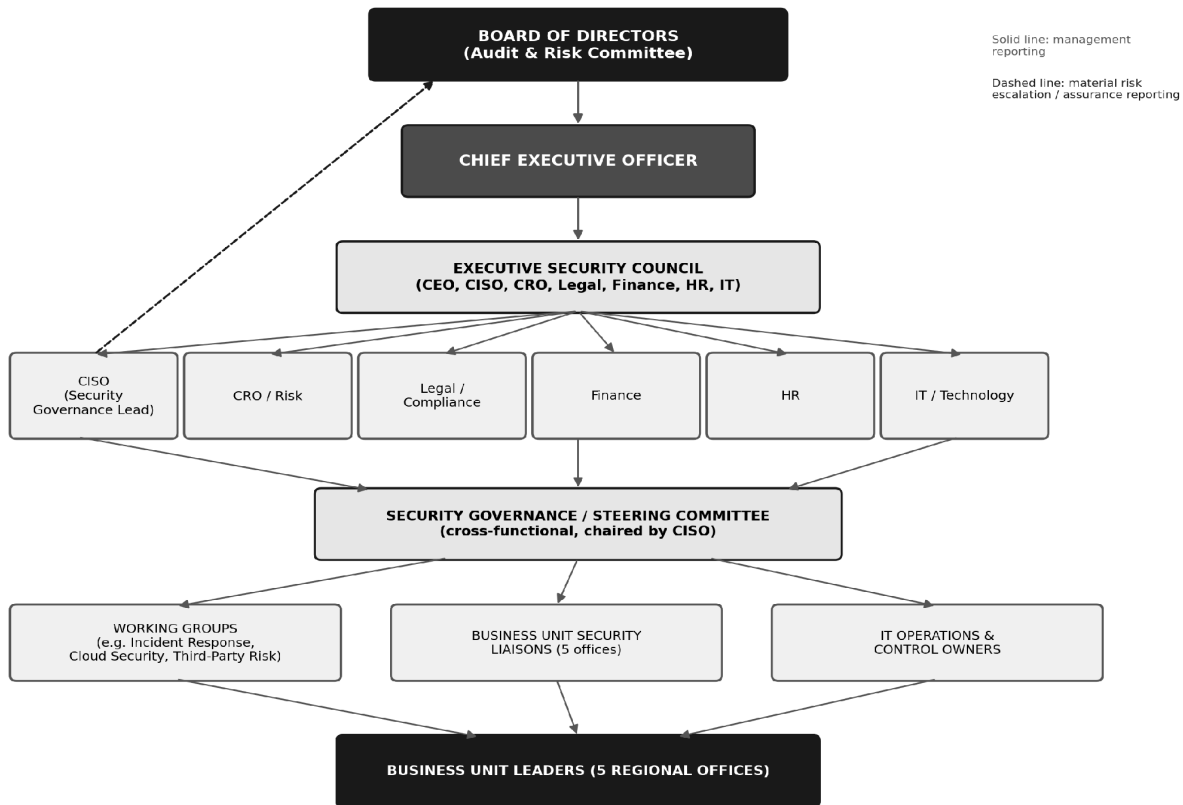
The map below sets out authority, interest, information needs and expected governance contribution for each stakeholder group in the redesigned model.

Stakeholder	Authority / Influence	Primary Interest	Information Needed	Governance Contribution
Board of Directors	Ultimate oversight authority; sets risk appetite and approves material risk decisions.	Regulatory exposure, brand reputation, assurance that cyber risk is managed.	Quarterly material risk summary, incident notifications above threshold, annual governance assurance report.	Approves risk appetite and strategy; ratifies material risk decisions; holds executive management to account.
CEO	Executive accountability for business performance and risk-adjusted growth.	Growth, strategic alignment, acceptable risk exposure.	Monthly security posture summary, escalations requiring executive decision, budget requests.	Chairs Executive Security Council; approves strategy and budget; escalates material risk to Board.
CISO	Leads security governance, policy and risk oversight; chairs Steering Committee.	Programme effectiveness, policy compliance, risk visibility.	Operational risk data, incident metrics, control testing results, audit findings.	Owns security strategy, policy and architecture approval; drives committee agenda and reporting.

Stakeholder	Authority / Influence	Primary Interest	Information Needed	Governance Contribution
CRO / Risk	Owns enterprise risk methodology and formal risk acceptance authority.	Risk aggregation, consistent methodology, treatment tracking.	Risk register entries, risk assessment outputs, incident risk ratings.	Approves enterprise risk assessments; accountable for risk acceptance decisions above threshold.
Legal Compliance /	Provides legal and regulatory advice; owns statutory notification decisions.	Regulatory duty, contractual exposure, privacy, evidence handling.	Incident facts, data categories affected, contractual and jurisdictional context.	Advises committees; holds final authority on regulatory notification; reviews third-party contracts.
Finance	Owns financial governance and budget approval.	Budget discipline, loss exposure, return on security investment.	Business cases, loss estimates, investment proposals.	Approves security budget against risk-based business case; tracks financial exposure from incidents.
Human Resources	Owns people governance, including joiner, mover and leaver controls.	Workforce conduct, awareness, disciplinary process.	Starters, leavers, role changes, awareness completion data.	Triggers access provisioning and revocation events; runs awareness and conduct programmes.
IT / Technology	Delivers and operates technology and technical controls.	Secure operation, service continuity, implementation quality.	Control requirements, architecture standards, incident technical detail.	Implements approved controls; executes technical response; reports operational metrics to CISO.
Business Unit Leaders	Own local operational performance and day-to-day risk decisions.	Operational performance, local risk, practical control implementation.	Applicable policy, local risk exposure, escalation thresholds.	Implement controls locally; escalate risk through BU liaison; participate in governance forums.

Security Governance Organisation Chart

The chart below connects the Board, executive management, the CISO and peer functions, the cross-functional committee, and the five business unit offices. Solid lines are management reporting lines; the dashed line is the material risk escalation and assurance path from the CISO to the Board through the Audit & Risk Committee.



Consultant Justification

The proposed structure is proportionate to a 2,500-employee technology organisation operating across five offices for four reasons.

- Scale without excess layers. A three-tier model, Board oversight, an Executive Security Council, and a Security Governance Committee with working groups, gives TechGlobal enough structure to coordinate a workforce of this size without adding committees that a smaller governance team could not realistically staff or sustain.
- Matches distributed footprint. Business unit security liaisons and a monthly Business Unit Security Forum give each of the five offices a direct, formal channel into central governance, so local risk is visible without each office running a separate, disconnected security function.
- Clear escalation without bottlenecks. Day-to-day decisions stay with IT and business unit teams; only risks that meet defined thresholds move up to the Executive Security Council or the Board. This keeps the model fast for routine matters and rigorous for material ones.
- Segregation of duties built in. Separating the CISO (governance and policy) from IT (technical delivery), and giving the CRO independent risk acceptance authority, removes the single point of concentrated authority that defines the current model.

This structure is also intentionally lightweight to implement. It reuses existing management roles rather than creating new headcount, and it can be phased in over one to two quarters: committees and terms of reference first, then the RACI model and escalation workflow, then the segregation-of-duties controls described in Task 5.

Task 2: Governance Responsibility and Authority Matrix

Role Profiles

Each profile below defines purpose, core responsibilities, decision authority, reporting obligations and at least two performance indicators for the eight core governance roles.

Board of Directors	
Purpose	Provide ultimate oversight of cyber risk and hold executive management accountable for the security programme.
Core Responsibilities	Approve risk appetite; review material cyber risk quarterly; ratify Board-level risk acceptance; commission independent assurance where needed.
Decision Authority	Approves risk appetite statement; approves cybersecurity strategy on CEO and CISO recommendation; ratifies acceptance of material (Level 3) risk; approves governance model changes.
Reports / Escalates To	Reports to shareholders and regulators; receives reports from CEO and CISO via the Audit & Risk Committee.
KPIs / Evidence	Percentage of material risks reviewed within target timeframe; independent assurance findings closed within agreed deadlines.

Chief Executive Officer	
Purpose	Own executive accountability for balancing growth with acceptable cyber risk.
Core Responsibilities	Chair the Executive Security Council; approve strategy and budget; escalate material risk to the Board; sponsor the governance programme.
Decision Authority	Co-develops and recommends cybersecurity strategy for Board approval; accountable for annual budget approval and Level 2 (executive) risk decisions.
Reports / Escalates To	Reports to the Board; receives input from CISO, CRO, Legal, Finance, HR and IT.
KPIs / Evidence	Security budget approved on schedule; percentage of Level 2 escalations resolved within target time.

Chief Information Security Officer	
Purpose	Lead security governance, policy, architecture and risk reporting.
Core Responsibilities	Draft strategy and policy; chair the Security Governance Committee; own architecture approval; report risk posture to the Council and Board.
Decision Authority	Approves security policy and architecture; accountable for incident response governance and awareness programme.
Reports / Escalates To	Reports to CEO (and functionally to the Board on assurance matters); escalates to Executive Security Council.
KPIs / Evidence	Policy review completed on schedule; mean time to detect and contain incidents; percentage of critical vulnerabilities remediated within SLA.

Chief Risk Officer / Risk	
Purpose	Own enterprise risk methodology and integrate cyber risk into the enterprise risk register.

Core Responsibilities	Run enterprise cyber-risk assessments; hold formal risk acceptance authority above defined thresholds; track treatment plans.
Decision Authority	Accountable for risk acceptance decisions above the operational threshold; approves risk assessment methodology.
Reports / Escalates To	Reports to CEO and Board Audit & Risk Committee.
KPIs / Evidence	Risk register currency (percentage updated within cycle); percentage of accepted risks with a documented review date.

Legal / Compliance	
Purpose	Provide legal and regulatory advice and own statutory notification decisions.
Core Responsibilities	Advise committees on regulatory duty; review third-party contracts for security clauses; hold final authority on breach notification.
Decision Authority	Holds final accountability for the regulatory notification decision; provides mandatory legal sign-off on data processing and third-party contract clauses that feed into the CISO-led third-party security review.
Reports / Escalates To	Reports to CEO; provides mandatory input to CISO and Executive Security Council during incidents.
KPIs / Evidence	Regulatory notifications made within statutory deadlines; percentage of third-party contracts with reviewed security clauses.

Finance	
Purpose	Own financial governance for the security programme.
Core Responsibilities	Approve budget allocation against risk-based business cases; track financial exposure from incidents; support investment prioritisation.
Decision Authority	Approves security budget within CEO-approved envelope; approves financial elements of major vendor contracts.
Reports / Escalates To	Reports to CEO; provides financial input to Executive Security Council.
KPIs / Evidence	Budget variance against plan; cost of incidents versus prior year; return on security investment tracked annually.

Human Resources	
Purpose	Own people governance controls relevant to security.
Core Responsibilities	Trigger joiner, mover and leaver access events; run security awareness and conduct programmes; support disciplinary process for policy breaches.
Decision Authority	Responsible for triggering access governance events (joiner, mover, leaver) and delivering the awareness programme, both under the CISO's overall accountability; approves conduct-related disciplinary action.
Reports / Escalates To	Reports to CEO; works jointly with IT and CISO on access governance.
KPIs / Evidence	Awareness programme completion rate; time to revoke access on leaver notification; number of repeat policy breaches.

IT / Technology

Purpose	Deliver, operate and maintain technical controls and infrastructure.
Core Responsibilities	Implement approved architecture and controls; execute technical incident response; maintain vulnerability management and access provisioning.
Decision Authority	Responsible for control implementation and Level 1 (operational) incident decisions; no independent approval authority over its own controls.
Reports / Escalates To	Reports to CEO for service delivery; reports to CISO for security control performance.
KPIs / Evidence	Patch and vulnerability remediation SLA compliance; system availability; mean time to remediate control gaps.

Cross-Functional Governance Responsibility Matrix

The summary matrix below consolidates decision authority, reporting lines and headline KPIs for quick reference across all eight roles.

Role	Purpose	Decision Authority	Reports / Escalates To	KPIs / Evidence
Board of Directors	Provide ultimate oversight of cyber risk and hold executive management accountable for the security programme.	Approves risk appetite statement; approves cybersecurity strategy on CEO and CISO recommendation; ratifies acceptance of material (Level 3) risk; approves governance model changes.	Reports to shareholders and regulators; receives reports from CEO and CISO via the Audit & Risk Committee.	Percentage of material risks reviewed within target timeframe; independent assurance findings closed within agreed deadlines.
Chief Executive Officer	Own executive accountability for balancing growth with acceptable cyber risk.	Co-develops and recommends cybersecurity strategy for Board approval; accountable for annual budget approval and Level 2 (executive) risk decisions.	Reports to the Board; receives input from CISO, CRO, Legal, Finance, HR and IT.	Security budget approved on schedule; percentage of Level 2 escalations resolved within target time.
Chief Information Security Officer	Lead security governance, policy, architecture and risk reporting.	Approves security policy and architecture; accountable for incident response governance and awareness programme.	Reports to CEO (and functionally to the Board on assurance matters); escalates to Executive Security Council.	Policy review completed on schedule; mean time to detect and contain incidents; percentage of critical vulnerabilities remediated within SLA.
Chief Risk Officer / Risk	Own enterprise risk methodology and integrate cyber risk into the enterprise risk register.	Accountable for risk acceptance decisions above the operational threshold; approves risk assessment methodology.	Reports to CEO and Board Audit & Risk Committee.	Risk register currency (percentage updated within cycle); percentage of accepted risks with a documented review date.
Legal Compliance /	Provide legal and regulatory advice and own statutory notification decisions.	Holds final accountability for the regulatory notification decision; provides mandatory legal sign-off on data processing and third-party contract clauses that feed into the CISO-led third-party security review.	Reports to CEO; provides mandatory input to CISO and Executive Security Council during incidents.	Regulatory notifications made within statutory deadlines; percentage of third-party contracts with reviewed security clauses.
Finance	Own financial governance for the security programme.	Approves security budget within CEO-approved envelope; approves financial elements of major vendor contracts.	Reports to CEO; provides financial input to Executive Security Council.	Budget variance against plan; cost of incidents versus prior year; return on security investment tracked annually.

Role	Purpose	Decision Authority	Reports / Escalates To	KPIs / Evidence
Human Resources	Own people governance controls relevant to security.	Responsible for triggering access governance events (joiner, mover, leaver) and delivering the awareness programme, both under the CISO's overall accountability; approves conduct-related disciplinary action.	Reports to CEO; works jointly with IT and CISO on access governance.	Awareness programme completion rate; time to revoke access on leaver notification; number of repeat policy breaches.
IT / Technology	Deliver, operate and maintain technical controls and infrastructure.	Responsible for control implementation and Level 1 (operational) incident decisions; no independent approval authority over its own controls.	Reports to CEO for service delivery; reports to CISO for security control performance.	Patch and vulnerability remediation SLA compliance; system availability; mean time to remediate control gaps.

Conflict Resolution Note

Formalising decision rights inevitably surfaces places where authority could overlap. The table below identifies four such areas and the principle the governance model uses to resolve each one without adding unnecessary bureaucracy.

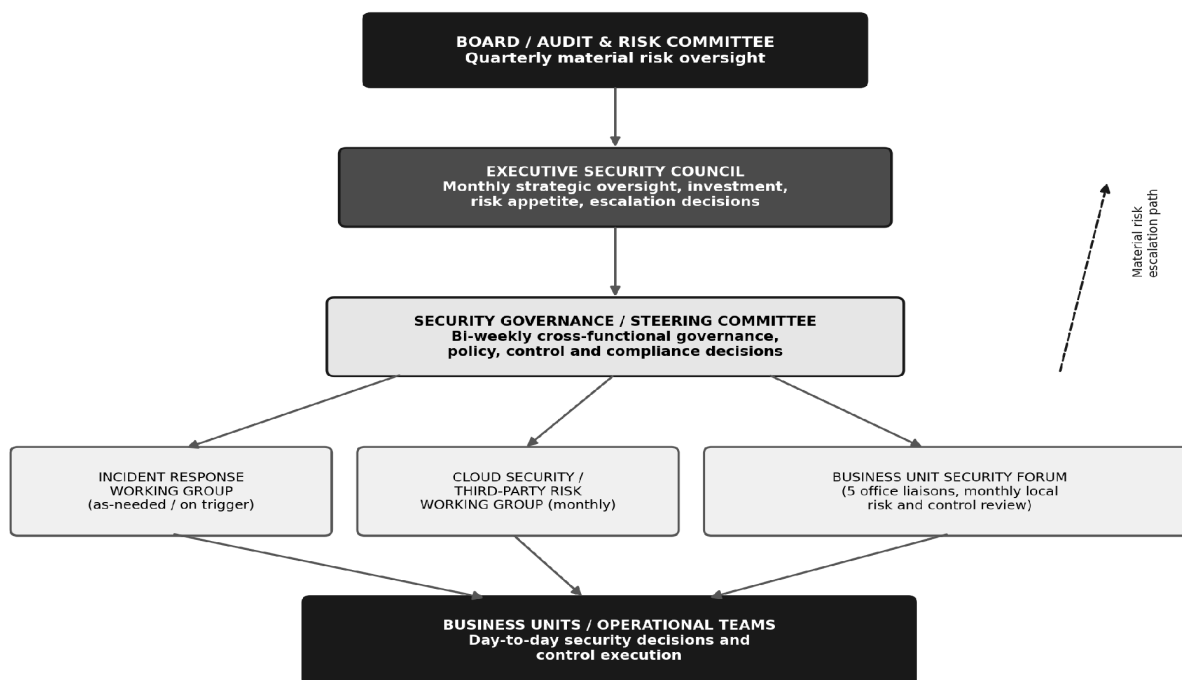
Overlap Area	Nature of the Conflict	Resolution Principle
Risk acceptance authority	CISO and CRO both have a legitimate view on whether a risk should be accepted; the CISO understands the technical detail, the CRO holds the formal enterprise authority.	The CRO retains formal accountability for risk acceptance above the defined threshold, but acceptance is invalid without a documented CISO technical assessment attached to the decision record.
Security budget prioritisation	IT, Finance and the CISO all have input into what gets funded, creating a risk that investment follows the loudest voice rather than the highest risk.	The CISO owns the risk-based investment case; Finance approves against the budget envelope and financial controls; unresolved disagreement is arbitrated by the Executive Security Council, not decided bilaterally.
Regulatory notification timing	Legal holds the statutory notification decision, but that decision depends on technical facts that only CISO and IT can confirm quickly.	Legal keeps final decision authority, but the escalation workflow (Task 5) sets a mandatory technical input deadline so Legal is never deciding without current facts, and statutory deadlines are not put at risk.
Access governance ownership	HR triggers joiner, mover and leaver events; IT executes the technical change. Overlap can leave both parties assuming the other has acted.	HR is accountable for triggering the event within one business day of the change; IT is accountable for executing and confirming the technical change within a matched SLA; both actions are logged and reconciled quarterly.

The common thread across all four resolutions is that overlap is resolved by defining one accountable decision-maker and a mandatory, time-bound input from the other party, rather than by requiring joint sign-off. Joint sign-off tends to slow decisions down and blur accountability when something goes wrong; a single accountable owner with a documented mandatory input preserves speed while still capturing the necessary expertise.

Task 3: Security Governance Committee Ecosystem

Committee Structure and Interaction Diagram

The ecosystem below has three formal forums and one operational layer. The Executive Security Council sets strategy and handles executive-level escalation. The Security Governance Committee makes cross-functional governance decisions on a regular cadence. Working groups and the Business Unit Security Forum feed structured input upward and carry decisions back down to operational teams, so business units participate in governance without running separate, disconnected security functions.



TechGlobal Security Governance Committee Ecosystem

Executive Security Council

- Purpose: strategic oversight of the security programme, investment decisions, risk appetite, and Level 2 (executive) risk escalation.
- Membership: CEO (chair), CISO, CRO, Legal, Finance, HR and IT leads.
- Cadence: monthly, plus ad hoc sessions for material escalations.
- Decision rights: approves strategy and annual budget; ratifies Level 2 risk decisions; refers material risk to the Board.

Security Governance / Steering Committee

- Purpose: cross-functional governance decisions on policy, architecture, compliance and operational risk.
- Membership: CISO (chair), IT, Legal, HR, Finance representative, CRO representative, and rotating business unit liaisons.
- Cadence: bi-weekly.
- Decision rights: approves policy and control changes within delegated authority; escalates unresolved or material items to the Executive Security Council.

Working Group: Incident Response

- Purpose: maintain incident response readiness and lead technical response during live incidents.
- Membership: IT Security Operations (lead), Legal, HR, Communications and relevant business unit representative, convened on trigger.
- Cadence: quarterly readiness review, plus activation on any Level 1 or higher incident.
- Decision rights: operational containment and remediation decisions; escalates classification and notification decisions per the workflow in Task 5.

Business Unit Participation

Each of the five offices nominates a Business Unit Security Liaison who sits on a monthly Business Unit Security Forum and rotates through the Security Governance Committee. This gives every office a direct channel into central governance and a route to escalate local risk, without creating a separate, parallel security function in each location. Business units retain ownership of day-to-day control execution, but policy, architecture and risk acceptance decisions run through the central committees described above.

Decision and Risk Information Flow

Operational risk and incident data flow up through the Security Governance Committee to the Executive Security Council on a monthly basis. Any item that meets the Level 3 threshold defined in Task 5 is escalated directly to the Board Audit & Risk Committee, which also receives a quarterly summary of all governance activity regardless of materiality. This dual path, routine quarterly reporting plus immediate escalation for material items, ensures the Board is never surprised by a risk that governance forums already knew about.

Terms of Reference: Security Governance Committee

Section	Detail
Purpose	To make cross-functional decisions on security policy, architecture, compliance and operational risk, and to provide a structured escalation route to the Executive Security Council.
Scope	All TechGlobal business units and offices; all information systems, third-party services and data processing activities within TechGlobal's risk boundary.
Membership and Chair	Chaired by the CISO. Standing members: IT lead, Legal representative, HR representative, Finance representative, CRO representative. Rotating members: one Business Unit Security Liaison per meeting.
Authority	Approves policy, architecture and control changes within delegated limits; approves Level 1 risk treatment plans; refers items exceeding delegated authority to the Executive Security Council.
Meeting Cadence and Quorum	Bi-weekly, minimum 60 minutes. Quorum is the Chair plus four standing members, with at least one of Legal or CRO present.
Inputs	Incident and vulnerability metrics, risk register updates, working group reports, business unit risk items, audit and assurance findings.
Outputs	Approved policy and control decisions, updated decision log, escalation items for the Executive Security Council, actions with named owners and due dates.
Reporting Line	Reports to the Executive Security Council monthly and provides input to the quarterly Board Audit & Risk Committee report.
Review Cycle	Terms of Reference reviewed annually or upon material change to the governance structure.

Sample Committee Agenda

Time	Agenda Item	Owner
09:00 - 09:05	Welcome, quorum check, approval of previous minutes	Chair (CISO)
09:05 - 09:20	Review of open actions and decision log	Committee Secretary
09:20 - 09:40	Operational risk and incident summary (prior period)	IT / Security Operations
09:40 - 09:55	Vulnerability and patch compliance status	IT
09:55 - 10:10	Policy and control changes for approval	CISO
10:10 - 10:25	Third-party and business unit risk items	Legal / BU Liaisons
10:25 - 10:40	Working group updates (Incident Response, Cloud Security)	Working Group Leads
10:40 - 10:55	Items for escalation to Executive Security Council	Chair (CISO)
10:55 - 11:00	Actions confirmed, next meeting date	Chair (CISO)

Sample Decision Log

Date	Decision / Issue	Decision Owner	Decision	Rationale	Actions / Owner	Review Date
12 Feb 2026	Approval of updated remote access policy	CISO	Approved with mandatory MFA for all remote sessions	Rising remote access risk following office expansion; aligns with architecture standard	IT to enforce MFA by 30 Apr 2026 / IT Manager	31 May 2026
06 Mar 2026	Third-party vendor risk exception request (payroll provider)	CISO (Legal consulted)	Conditional approval for 90 days pending vendor SOC 2 report	Vendor could not provide current report at contract renewal; business continuity risk if service lapses	Procurement to obtain SOC 2 report / Procurement Lead	05 Jun 2026
18 Apr 2026	Cloud storage misconfiguration incident, root cause review	CISO	Accepted root cause; approved automated configuration scanning tool	Manual review process failed to catch public bucket exposure; automated control reduces recurrence risk	IT to deploy scanning tool / Cloud Security Working Group	18 Jul 2026
09 May 2026	Security awareness completion below target in two offices	CISO (HR consulted)	Approved mandatory catch-up training with manager escalation for non-completion	Completion at 68 percent against 95 percent target; increases phishing susceptibility	HR to schedule catch-up sessions / HR Business Partners	09 Aug 2026

Twelve-Month Governance Calendar

Month	Governance Activity / Milestone
January	Security Governance Committee (bi-weekly), annual risk assessment cycle begins
February	Security Governance Committee, Executive Security Council (monthly), policy annual review begins
March	Security Governance Committee, Board Audit & Risk Committee (quarterly report), Q1 close
April	Security Governance Committee, Executive Security Council, incident response tabletop exercise
May	Security Governance Committee, business continuity plan review, third-party risk annual review
June	Security Governance Committee, Board Audit & Risk Committee (quarterly report), Q2 close, mid-year risk register refresh
July	Security Governance Committee, Executive Security Council, security budget planning for next fiscal year begins
August	Security Governance Committee, access recertification cycle (all business units)
September	Security Governance Committee, Board Audit & Risk Committee (quarterly report), Q3 close, independent control testing
October	Security Governance Committee, Executive Security Council, annual security budget approval, awareness programme refresh
November	Security Governance Committee, incident response tabletop exercise, vendor risk annual review
December	Security Governance Committee, Board Audit & Risk Committee (annual report and risk appetite review), year-end assurance summary

Task 4: RACI Accountability Matrix

The matrix below covers the fifteen governance activities specified in the brief across all nine core roles. Each activity has exactly one Accountable role, consistent with good RACI practice.

Governance Activity	Board	CEO	CISO	CRO	Legal	Finance	HR	IT	BU Lead
Cybersecurity strategy approval	A	R	R	C	C	C	I	I	I
Security policy approval	I	I	A	C	C	I	C	R	I
Enterprise cyber-risk assessment	I	I	R	A	C	C	I	R	C
Risk acceptance	I	C	C	A	C	C	I	I	C
Security budget approval	I	A	R	I	I	R	I	C	I
Security architecture approval	I	I	A	I	I	I	I	R	I
Third-party security review	I	I	A	C	R	C	I	R	C
Access governance	I	I	A	I	I	I	R	R	C
Incident response governance	I	I	A	I	C	I	C	R	C
Material incident escalation	I	A	R	C	C	I	I	R	R
Regulatory notification decision	I	C	C	C	A	I	I	I	I
Security awareness programme	I	I	A	I	I	I	R	C	R
Vulnerability remediation oversight	I	I	A	I	I	I	I	R	C
Business continuity / recovery governance	I	C	C	A	C	C	C	R	R
Board cyber-risk reporting	I	A	R	C	I	I	I	I	I

Legend: A = Accountable (one role per activity) R = Responsible C = Consulted I = Informed

Problematic Assignments

Formalising the matrix surfaced four assignments worth flagging, because a single Accountable role does not, on its own, remove the risk of delay or blurred coordination.

Activity	Why It Is Problematic	Recommended Adjustment
Risk acceptance	CRO holds Accountable status, but the CISO carries the technical detail needed to judge the risk properly. A formal authority sitting apart from technical knowledge can lead to decisions made without full context, or to the CRO simply rubber-stamping the CISO's view, which defeats the purpose of independent challenge.	Require a documented CISO technical assessment attached to every risk acceptance decision above the operational threshold, with the CRO's sign-off recording that the assessment was reviewed, not just received.
Regulatory notification decision	Legal is Accountable, but statutory notification clocks (commonly 72 hours) start running before Legal has the technical facts needed to decide. A bottleneck here risks a missed statutory deadline.	Set a mandatory technical input SLA, for example CISO and IT must deliver a confirmed impact assessment to Legal within a fixed number of hours of an incident being classified as a potential breach.
Security budget approval	CEO is Accountable and Finance is Responsible, while the CISO, who best understands where risk-based investment is needed, only has a Consulted-equivalent voice through the strategy process. Budget decisions can end up driven by cost control rather than risk priority.	Require the CISO's risk-based investment case to be a mandatory attachment to any budget submission, and give the CISO a standing right to escalate a declined risk-critical item to the Executive Security Council before the budget is finalised.
Material incident escalation	CISO, IT and Business Unit leads are all Responsible at the same time. During a live incident this can blur who is actually directing the response on the ground versus who is making the go or no-go call on escalation.	Nominate a single incident commander (normally CISO or delegate) for the duration of any Level 2 or higher incident, so the multiple Responsible roles operate under one point of coordination rather than in parallel.

Implementation Guide: Using the RACI Matrix

During Planning

- Before starting any new initiative that touches security (a new system, a new vendor, a policy change), identify which of the fifteen activities it falls under and confirm the Accountable role before work begins.
- Consulted roles should be engaged early enough that their input can actually change the plan, not asked to review a decision that has already been made.

During Approvals

- An approval is only valid if it is given or delegated by the Accountable role named in the matrix. Approvals given by a Responsible or Consulted role should be treated as provisional pending Accountable sign-off.
- Record every approval in the decision log (Task 3) with the Accountable role's name, the date, and the rationale.

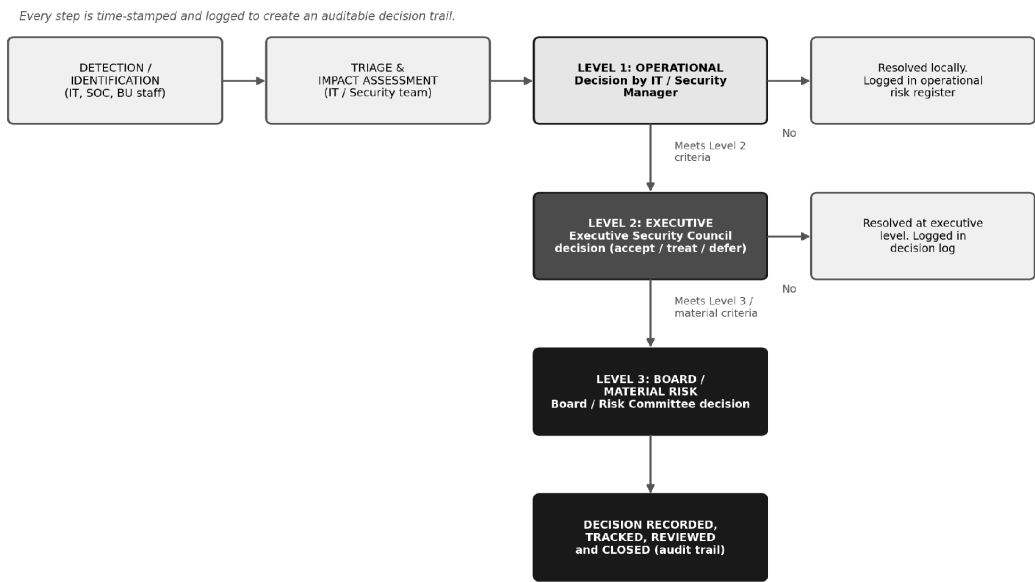
During Incidents

- Refer to the Material Incident Escalation and Regulatory Notification Decision rows immediately on detection of a potential material incident, and nominate a single incident commander as described in section 4.1.
- Informed roles should receive updates on a fixed cadence during an incident, for example every two hours, so they are not left to chase status updates while response is underway.
- After closure, use the matrix to confirm that every Responsible and Accountable role completed its part before the incident is marked closed in the decision log.

Task 5: Cyber-Risk Escalation and Segregation of Duties

Major Cyber-Risk Escalation Workflow

The workflow below begins at operational detection and ends at the appropriate executive or Board decision, with every step logged to build an auditable decision trail. Three escalation levels are used: Operational, Executive, and Board or Material Risk.



TechGlobal Major Cyber-Risk Escalation Workflow

Escalation Threshold Table

The table below defines the trigger criteria, decision authority, required notification and target response time for each escalation level.

Level	Example Trigger	Decision Authority	Required Notification	Target Response Time
Level 1Operational	Single system affected, contained within one team, no confirmed data exposure, no regulatory trigger, low business impact.	IT / Security Operations Manager	Logged to Security Governance Committee (routine reporting, no immediate notification required)	Contain within 4 hours; resolve within 24 hours
Level 2Executive	Confirmed data exposure, multiple systems or more than one business unit affected, financial exposure above a defined threshold, service disruption beyond 4 hours, or a vendor breach affecting TechGlobal data.	Executive Security Council	CEO, Legal and affected business unit leads notified within 4 hours of confirmation	Council convened within 8 hours; decision within 24 hours

Level	Example Trigger	Decision Authority	Required Notification	Target Response Time
Level 3 Board / Material	Confirmed material customer or regulatory data breach, financial exposure above the Board-approved materiality threshold, credible reputational or media risk, mandatory regulatory notification triggered, or multi-office critical service outage.	Board / Audit & Risk Committee (CEO recommends, Board decides)	Board notified within 24 hours; regulators notified per statutory deadline (for example 72 hours)	Board session within 48 hours; weekly review until closed

Segregation-of-Duties and Accountability Weakness Register

The register below sets out six weaknesses identified in TechGlobal's current IT-centric model, the risk each creates, and a proportionate control recommendation for each. Controls are designed to reduce conflict without adding unnecessary bureaucracy: each relies on an existing role gaining a check, rather than a new layer of sign-off.

ID	Weakness / Conflict	Risk Created	Roles Involved	Recommended Control	Residual Risk / Review
1	The IT Director designs, implements and approves security controls with no independent review.	Control quality goes unchallenged; self-approval bias; no independent evidence that controls are adequate.	IT Director	Separate the CISO role from IT delivery and give the CISO independent policy and control approval authority; introduce periodic independent control testing.	Low, reviewed annually
2	The same team provisions user access and later reviews whether that access is still appropriate.	Unauthorised or stale access can go undetected for long periods, increasing insider and account-compromise risk.	IT	HR triggers all provisioning events; business unit leaders, independent of IT, perform quarterly access recertification; results reported to the Security Governance Committee.	Low to medium, reviewed quarterly
3	The IT Director approves security budget requests that fund their own department's priorities and performance targets.	Investment may be prioritised for convenience or internal politics rather than actual risk.	IT Director, Finance	Finance co-approves against a documented, risk-based business case authored by the CISO; the Executive Security Council reviews the annual investment plan.	Low, reviewed annually
4	No independent function exists to challenge a risk owner who accepts a high risk without escalation.	Material risks can be silently accepted and never surface to executive management or the Board.	Business Unit Leaders, IT	Formal risk acceptance thresholds tied to the escalation workflow above; the CRO or Executive Security Council must ratify any acceptance above the operational threshold.	Low, reviewed semi-annually
5	Incident responders also lead the post-incident review of their own response, with no independent input.	Under-reporting of process errors and incomplete lessons learned reduce future incident readiness.	IT / Security Operations	An independent reviewer, drawn from the Security Governance Committee and not involved in the response, co-leads every post-incident review; findings are recorded in the decision log.	Low, reviewed per incident

ID	Weakness / Conflict	Risk Created	Roles Involved	Recommended Control	Residual Risk Review /
6	Legal and Compliance are not systematically involved when business units sign third-party contracts that involve data access.	Contracts can be signed with weak security clauses or unclear breach notification duties, creating exposure that surfaces only after an incident.	Business Units, Procurement / IT	Mandatory Legal and CISO sign-off on any third-party contract involving data access above a defined data-sensitivity threshold.	Low, reviewed annually

Decision Recording and Assurance Note

Every decision made at Level 1, 2 or 3 is recorded in a central decision log, using the format demonstrated in Task 3, maintained by the Security Governance Committee secretariat. Each entry carries a unique reference, a named decision owner, the rationale, agreed actions with owners and due dates, and a review date.

- Recording: decisions are logged at the point they are made, not retrospectively, so the log reflects what was actually decided and by whom.
- Tracking: open actions are reviewed at every Security Governance Committee meeting; overdue actions are automatically flagged to the Executive Security Council.
Review: the Executive Security Council reviews all Level 2 and Level 3 entries quarterly to confirm decisions remain valid and risks have not changed materially.
- Closure: an entry is closed only when its actions are complete and independently confirmed, not simply when the action owner reports completion.
- Assurance: a summary of the decision log, including any overdue items, is provided to the Board Audit & Risk Committee quarterly; the full log is retained in line with TechGlobal's records retention policy (recommended minimum of seven years) to support audit and regulatory review.

Together, the escalation workflow, threshold table, weakness register and decision log give TechGlobal a consistent, auditable trail from the moment a cyber risk is identified to the moment it is formally closed, addressing the Board's current lack of visibility identified in Task 1.